



# CASE STUDY: DARKSIDE RANSOMWARE ATTACK ON COLONIAL PIPELINE

Cybersecurity for the Operational Technology  
Environment (CyOTE)

**31 MARCH 2022**



U.S. DEPARTMENT OF  
**ENERGY**

OFFICE OF  
Cybersecurity, Energy Security,  
and Emergency Response

**INL/RPT-22-67337**

This document was prepared by Idaho National Laboratory (INL) under an agreement with and funded by the U.S. Department of Energy.

INL is a U.S. Department of Energy National Laboratory operated by Battelle Energy Alliance, LLC

This *paper* is the product of *research* conducted by the Cybersecurity for the Operational Technology Environment (CyOTE) program and was funded by the Department of Energy Office of Cybersecurity, Energy Security and Emergency Response (DOE CESER). No updates have been made since the date of publication and no further funding has been approved.

TABLE OF CONTENTS

1. EXECUTIVE SUMMARY ..... 1

2. INTRODUCTION..... 2

2.1. APPLYING THE CYOTE METHODOLOGY .....2

2.2. BACKGROUND ON THE ATTACK.....4

3. OBSERVABLE AND TECHNIQUE ANALYSIS ..... 6

3.1. EXTERNAL REMOTE SERVICES TECHNIQUE (T0822) FOR INITIAL ACCESS .....6

3.2. VALID ACCOUNTS TECHNIQUE (T0859) FOR PERSISTENCE .....7

3.3. EXPLOITATION FOR PRIVILEGE ESCALATION (T0890) FOR PRIVILEGE ESCALATION .....8

3.4. STANDARD APPLICATION LAYER PROTOCOL TECHNIQUE (T0869) FOR COMMAND AND CONTROL.....9

3.5. CONNECTION PROXY TECHNIQUE (T0884) FOR COMMAND AND CONTROL.....10

3.6. DATA FROM INFORMATION REPOSITORIES TECHNIQUE (T0811) FOR COLLECTION .....11

3.7. THEFT OF OPERATIONAL INFORMATION TECHNIQUE (T0882) FOR IMPACT .....12

3.8. DATA DESTRUCTION TECHNIQUE (T0809) FOR INHIBIT RESPONSE FUNCTION .....13

3.9. SERVICE STOP TECHNIQUE (T0881) FOR INHIBIT RESPONSE FUNCTION.....14

3.10. LOSS OF AVAILABILITY TECHNIQUE (T0826) FOR IMPACT.....15

3.11. LOSS OF PRODUCTIVITY AND REVENUE (T0828) FOR IMPACT .....16

APPENDIX A: OBSERVABLES LIBRARY .....18

APPENDIX B: ARTIFACTS LIBRARY .....21

APPENDIX C: OBSERVERS .....29

REFERENCES.....30

FIGURES

FIGURE 1. CYOTE METHODOLOGY ..... 2

FIGURE 2. COLONIAL PIPELINE ATTACK TIMELINE ..... 4

FIGURE 3. ATTACK GRAPH .....17

TABLES

TABLE 1. TECHNIQUES USED IN THE COLONIAL PIPELINE CYBER-ATTACK..... 5

TABLE 2. CASE STUDY QUANTITATIVE SUMMARY ..... 5

# CASE STUDY: DARKSIDE RANSOMWARE ATTACK ON COLONIAL PIPELINE

## 1. EXECUTIVE SUMMARY

The Darkside Ransomware Attack on Colonial Pipeline case study leverages publicly available information about the Colonial Pipeline cyber-attack and catalogs anomalous observables for each technique employed in the attack. This analysis is based upon the methodology of the Cybersecurity for the Operational Technology Environment (CyOTE) program.

On 7 May 2021, Colonial Pipeline Co., a Houston, Texas, based refined fuel pipeline operator, experienced a ransomware attack on their enterprise network, resulting in the company shutting down pipeline operations. Colonial's CEO, Joseph Blount, reported that an employee in the control center identified a ransom note on a system in the enterprise network that demanded payment to regain access to the system. The employee immediately notified the operations supervisor at the control center. The supervisor decided to halt operations to isolate the operational technology network from the attack.<sup>1</sup> This resulted in the shutdown of 5,500 miles of pipeline, which delivers refined fuel products to approximately 260 points across 13 states.<sup>2</sup> The outage impacted availability of commercial gasoline services, resulting in higher prices and consumer-driven shortages.<sup>3</sup> Shortly after discovering the ransomware note, Colonial paid a ransom of \$4.4 million to the adversaries for a decryption tool.<sup>4</sup> The company restarted its pipeline operations on 12 May 2021, five days after the initial shutdown.<sup>5</sup>

Researchers and analysts identified 11 techniques utilized during the attack with a total of 68 observables using the MITRE ATT&CK® for Industrial Control Systems Matrix. The CyOTE program assesses observables accompanying techniques used prior to the triggering event to identify opportunities to observe malicious activity. If observables accompanying the attack techniques are perceived and investigated prior to the triggering event, earlier comprehension of malicious activity can take place. Nine of the identified techniques used during the Colonial cyber-attack were precursors to the triggering event. Case study analysis identified 45 observables associated with these precursor techniques, 24 of which were assessed to have an increased likelihood of being perceived in the nine days preceding the execution of the ransomware. The response and comprehension time could have been reduced to less than five days if the observables had been identified earlier.

The information gathered in this case study contributes to a library of observables tied to a repository of artifacts, data sources, technique detection capabilities, and procedural recipes to support the comprehension of indicators of attack. Asset owners and operators can use these products if they perceive similar observables, or to prepare for comparable scenarios.

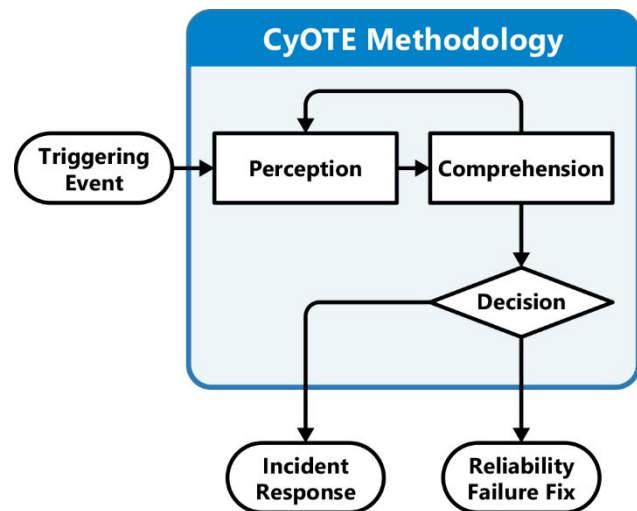
## 2. INTRODUCTION

The Cybersecurity for the Operational Technology Environment (CyOTE) program developed capabilities for energy sector asset owners and operators (AOOs) to independently identify adversarial tactics and techniques within their operational technology (OT) environments.

Led by Idaho National Laboratory (INL) under the leadership of the Department of Energy (DOE) Office of Cybersecurity, Energy Security, and Emergency Response (CESER), CyOTE is a partnership with energy sector owners and operators whose goal is to tie the impacts of a cyber-attack to anomalies in the OT environment to determine whether the anomalies have a malicious cyber cause.

### 2.1. APPLYING THE CYOTE METHODOLOGY

The CyOTE methodology, as shown in Figure 1, applies fundamental concepts of perception and comprehension to a universe of knowns and unknowns increasingly disaggregated into observables, anomalies, and triggering events. The program utilizes MITRE's ATT&CK® Framework for Industrial Control Systems (ICS) as a common lexicon to assess triggering events. By leveraging the CyOTE methodology with existing commercial monitoring capabilities and manual data collection, energy sector partners can understand relationships between multiple observables, which could represent a faint signal of an attack requiring investigation. CyOTE can assist AOOs in prioritizing their OT environment visibility investments.



**Figure 1. CyOTE Methodology**

Case studies such as this one support continued learning through analysis of historical incidents that have impacted OT. This case study is based on publicly available reports and provides examples of how key concepts in the CyOTE methodology appear in the real world, providing insights on how similar novel attacks could be detected earlier and therefore mitigated. The analysis enables AOOs to independently identify observables associated with techniques known to be indicators of attack within OT environments. The identified observables highlight anomalous events for further investigation, which could enhance comprehension of malicious activity.

A timeline of events is created based on the CyOTE methodology and the attack-related observables. The timeline includes assessed dates for initial access, the triggering event, and the date the victim comprehended the malicious activity. The point on this timeline when each technique appears is critical to the AOO's ability to perceive and comprehend the associated malicious activity. Perception of techniques early in the timeline is critical, since responding to those techniques will generally have greater potential to limit damage to operations.

Each technique has an assessed perceivability. Perceivability is a function of the number of observables and the potential for AOOs to detect those observables. If a technique includes

effects which AOOs may detect, such as deletion or modification of system files or required user execution, then the technique would be more perceivable.

Differences in infrastructure and system configurations may present different challenges and opportunities for observable detection. For example, architecture-wide endpoint monitoring is likely to improve the perceivability of techniques which modify host files, such as the Data Destruction technique (T0809) for Inhibit Response Function and Theft of Operational Information technique (T0882) for Impact. Network monitoring and log analysis capabilities are likely to improve perceivability of techniques which create malicious network traffic, such as the Standard Application Layer Protocol technique (T0869) for Command and Control, External Remote Services technique (T0822) for Initial Access, and Connection Proxy technique (T0884) for Command and Control. Alternatively, enhancing the monitoring parameters of system files would increase the perceivability of techniques such as Data from Information Repositories technique (T0811) for Collection and the Service Stop technique (T0881) for Inhibit Response Function.

The CyOTE program provides AOOs with a library of observables reported in each historical case. The library can be used in conjunction with a repository of artifacts, technique detection capabilities, and procedural recipes to support the comprehension of indicators of attack.

## 2.2. BACKGROUND ON THE ATTACK

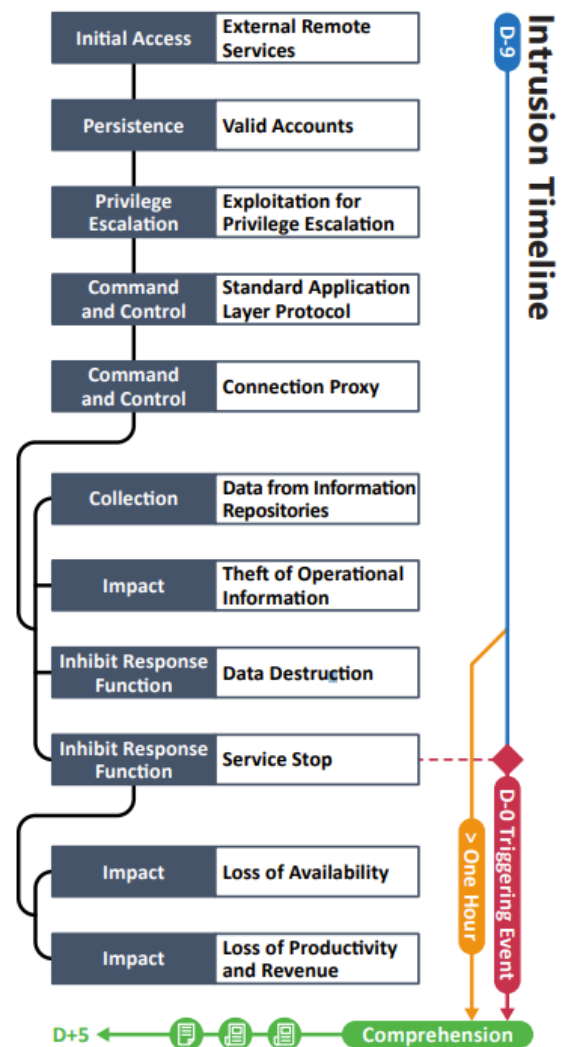
Adversaries gained initial network access to the Colonial Pipeline Co. (Colonial) enterprise environment on 29 April 2021, nine days before they executed their ransomware attack (D-9). Colonial operates the largest refined pipeline in the United States, which supplies fuel and fuel services to 260 locations across 13 states from Texas to New Jersey. At approximately 5:00 AM on 7 May, the triggering event (D-0) occurred when a pipeline operator observed a ransom note on a system display. The note demanded \$4.4 million in cryptocurrency. The operator quickly contacted their operations supervisor, who immediately began shutdown procedures along the 5,500-mile-long pipeline. By 6:10 AM the entire pipeline was shut down, although some operations continued under limited manual control between terminals and delivery points. Manual operation was utilized until 12 May (D+5) when automated systems were brought back online.<sup>6</sup>

A timeline of adversarial techniques is shown in Figure 2. The timeline includes the estimated number of days prior to and after the triggering event. The timeline after the triggering event includes the assessed victim comprehension timeline.

The adversaries gained initial access on 29 April through a virtual private network (VPN) connection with valid credentials from an expired account linked to a collection of leaked passwords on the dark web.<sup>7</sup> This occurred nine days (D-9) prior to the triggering event (D-0) when the ransom note was displayed and system files were encrypted. This nine-day gap allowed the adversaries to elevate privileges, deploy ransomware, and exfiltrate 100 GB of corporate data.<sup>8,9</sup>

The first details of the cyber-attack were reported on 7 May (D-0). Comprehension of the entire attack event occurred by 12 May (D+5) when Colonial brought all OT systems back online.

Mandiant assisted in the cyber-attack investigation and recovery effort. No technical reports on the cyber-attack were publicly released, resulting in CyOTE technical analysts having to rely on publicly available information and techniques previously associated with DarkSide ransomware. The DarkSide group provides this ransomware as ransomware-as-a-service (RaaS) to other entities willing to split profits from intended cyber-attacks.



**Figure 2. Colonial Pipeline Attack Timeline**



Analysis identified 11 techniques in a sequence and timeframe likely used by adversaries during this cyber-attack (**Error! Reference source not found.**). These attack techniques are defined according to MITRE's ATT&CK® for ICS framework.

**Table 1. Techniques Used in the Colonial Pipeline Cyber-Attack**

| Initial Access                      | Execution                 | Persistence            | Privilege Escalation                         | Evasion                   | Discovery                           | Lateral Movement                | Collection                                | Command and Control                        | Inhibit Response Function     | Impair Process Control       | Impact                                  |
|-------------------------------------|---------------------------|------------------------|----------------------------------------------|---------------------------|-------------------------------------|---------------------------------|-------------------------------------------|--------------------------------------------|-------------------------------|------------------------------|-----------------------------------------|
| Data Historian Compromise           | Change Operating Mode     | Modify Program         | <b>Exploitation for Privilege Escalation</b> | Change Operating Mode     | Network Connection Enumeration      | Default Credentials             | Automated Collection                      | Commonly Used Port                         | Activate Firmware Update Mode | Brute Force I/O              | Damage to Property                      |
| Drive-by Compromise                 | Command-Line Interface    | Module Firmware        | Hooking                                      | Exploitation for Evasion  | Network Sniffing                    | Exploitation of Remote Services | <b>Data from Information Repositories</b> | <b>Connection Proxy</b>                    | Alarm Suppression             | Modify Parameter             | Denial of Control                       |
| Engineering Workstation Compromise  | Execution through API     | Project File Infection |                                              | Indicator Removal on Host | Remote System Discovery             | Lateral Tool Transfer           | Detect Operating Mode                     | <b>Standard Application Layer Protocol</b> | Block Command Message         | Module Firmware              | Denial of View                          |
| Exploit Public-Facing Application   | Graphical User Interface  | System Firmware        |                                              | Masquerading              | Remote System Information Discovery | Program Download                | I/O Image                                 |                                            | Block Reporting Message       | Spoof Reporting Message      | <b>Loss of Availability</b>             |
| Exploitation of Remote Services     | Hooking                   | <b>Valid Accounts</b>  |                                              | Rootkit                   | Wireless Sniffing                   | Remote Services                 | Man in the Middle                         |                                            | Block Serial COM              | Unauthorized Command Message | Loss of Control                         |
| <b>External Remote Services</b>     | Modify Controller Tasking |                        |                                              | Spoof Reporting Message   |                                     | Valid Accounts                  | Monitor Process State                     |                                            | <b>Data Destruction</b>       |                              | <b>Loss of Productivity and Revenue</b> |
| Internet Accessible Device          | Native API                |                        |                                              |                           |                                     |                                 | Point & Tag Identification                |                                            | Denial of Service             |                              | Loss of Protection                      |
| Remote Services                     | Scripting                 |                        |                                              |                           |                                     |                                 | Program Upload                            |                                            | Device Restart/Shutdown       |                              | Loss of Safety                          |
| Replication Through Removable Media | User Execution            |                        |                                              |                           |                                     |                                 | Screen Capture                            |                                            | Manipulate I/O Image          |                              | Loss of View                            |
| Rogue Master                        |                           |                        |                                              |                           |                                     |                                 | Wireless Sniffing                         |                                            | Modify Alarm Settings         |                              | Manipulation of Control                 |
| Spearphishing Attachment            |                           |                        |                                              |                           |                                     |                                 |                                           |                                            | Rootkit                       |                              | Manipulation of View                    |
| Supply Chain Compromise             |                           |                        |                                              |                           |                                     |                                 |                                           |                                            | <b>Service Stop</b>           |                              | <b>Theft of Operational Information</b> |
| Wireless Compromise                 |                           |                        |                                              |                           |                                     |                                 |                                           |                                            | System Firmware               |                              |                                         |

**Table 2. Case Study Quantitative Summary**

| Case Study Quantitative Summary                           | Totals    |
|-----------------------------------------------------------|-----------|
| <b>MITRE ATT&amp;CK® for ICS Techniques</b>               | <b>11</b> |
| <b>Technique Observables</b>                              | <b>68</b> |
| <b>Precursor Techniques</b>                               | <b>9</b>  |
| <b>Precursor Technique Observables</b>                    | <b>45</b> |
| <b>Highly Perceivable Precursor Technique Observables</b> | <b>24</b> |



### 3. OBSERVABLE AND TECHNIQUE ANALYSIS

The following analysis may assist AOOs in identifying malicious cyber activity earlier and more effectively. The following techniques and observables were compiled from publicly available sources and correlated with expert analysis.

#### 3.1. EXTERNAL REMOTE SERVICES TECHNIQUE (T0822) FOR INITIAL ACCESS

Based on analysis conducted by Mandiant, the External Remote Services technique (T0822) was used to gain initial access through a VPN account, creating a tunnel directly to Colonial's enterprise network on 29 April 2021. With authenticated connection credentials, adversaries were able to maintain an unhindered connection to the enterprise environment.<sup>10</sup> IT staff, IT managers, and cybersecurity personnel may have been able to observe the creation of VPN connections.

With authentic credentials used to gain access to the enterprise environment, no alerts would have been raised unless parameters were previously set to trigger an alarm if a user logged in during unusual times or at an unusual location. The observables connected to this technique, due to its authorized nature, would coincide with permitted connectivity through VPN access.

A total of four observables were identified with the use of the External Remote Services Technique (T0822) and were likely present on victim networks for the longest period of time. These observables likely would have been visible to the network administrator, IT staff, and IT cybersecurity, and if identified and investigated earlier in the attack could have reduced comprehension time. This technique is important for investigation because it presents perceivable effects, such as user-privilege changes and event log creation from a legacy user. This technique also occurs early in the timeline and responding to this technique will effectively halt all future events. If the External Remote Services technique is detected and prevented, then subsequent techniques are not executed. Terminating the chain of techniques at the External Remote Services technique would prevent adversaries from accessing internal networks and delivering malicious payloads. Of the four observables associated with this technique, one of these observables is assessed to be highly perceivable (VPN Activity Timestamp).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                      |
|---------------------------------------------------------------|--------------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 59 artifacts could be generated by the External Remote Services technique |
| <b>Technique Observers<sup>a</sup></b>                        | IT Staff and IT Cybersecurity                                                        |

<sup>a</sup> Observer titles are adapted from the Job Role Groupings listed in the SANS ICS Job Role to Competency Level Poster. CyOTE products utilize these job categories rather than organizational titles to both support comprehensive analysis and preserve anonymity within the victim organization. A complete list of potential observers can be found in Appendix C

### 3.2. VALID ACCOUNTS TECHNIQUE (T0859) FOR PERSISTENCE

Adversaries employed the Valid Accounts technique (T0859) by utilizing an employee's VPN account credentials found in a collection of leaked passwords on the dark web. This was a legacy account that was not deactivated and which the adversaries used to gain persistent access to the enterprise network.<sup>11</sup>

IT staff and IT cybersecurity would have been able to observe use of the Valid Accounts Technique if account login notification parameters had been set. Among the observables gathered from the Valid Accounts technique were account login logs that showed a legacy account was being used. When this account was being used to log on, during regular or unusual hours, is not known from publicly available information. However, system logs would have a record of any successful log-on events.

A total of four observables were identified with the use of the Valid Accounts technique (T0859). Two of these observables are assessed to be highly perceivable (Leaked Credentials and Passwords Found on the Internet, VPN Activity Timestamp).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                            |
|---------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 15 artifacts could be generated by the Valid Accounts technique |
| <b>Technique Observers</b>                                    | IT Staff and IT Cybersecurity                                              |

### 3.3. EXPLOITATION FOR PRIVILEGE ESCALATION (T0890) FOR PRIVILEGE ESCALATION

The ransomware deployed by the adversaries after gaining access would then have checked to see if it was running on a system with elevated privileges. If it was not operating with administrator privileges, it would utilize the User Account Control (UAC) elevation technique to rerun itself, this time operating at an administrator level.<sup>12</sup>

The observers of this technique during the attack would be network administrators and IT personnel monitoring user privileges. Systems and network administrators may find artifacts associated with this technique in security event logs or alerts provisioned through Windows Defender event logs.

Malicious files or programs running under elevated user privileges have been found in similar cyber-attacks, along with the popular credential harvester tool Mimikatz. While its use in the attack against Colonial has not been confirmed, the popularity of Mimikatz is such that a number of observables and artifacts likely would coincide with its use. However, standard anti-virus software or other signature-based detection and prevention capabilities would have difficulty catching the use of this tool due to its changing of hash values.

A total of seven observables were identified with the use of the Exploitation for Privilege Escalation technique (T0890). Two of these observables are assessed to be highly perceivable (Security Event Log, Windows Defender Event Log).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                   |
|---------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 15 artifacts could be generated by the Exploitation for Privilege Escalation technique |
| <b>Technique Observers</b>                                    | IT Staff and IT Cybersecurity                                                                     |

### 3.4. STANDARD APPLICATION LAYER PROTOCOL TECHNIQUE (T0869) FOR COMMAND AND CONTROL

After the DarkSide ransomware infects a network, it begins to gather information about the operating system and other aspects of the victim network. The ransomware then exfiltrates the data to the command-and-control (C2) server. During delivery, a hash is created within the HTTP packet and sent to the C2 server to uniquely identify and organize information about the victim's infected systems.<sup>13</sup>

Network administrators, IT cybersecurity, and IT Staff would likely observe communications with external IP addresses, as compromised systems would communicate with C2 servers using HTTP POST requests to potentially suspect IP addresses.

A total of six observables were identified with the use of the Standard Application Layer Protocol technique (T0869). These observables likely would have been visible to the network administrator, IT staff, and IT cybersecurity, and if identified and investigated earlier in the attack could have reduced comprehension time. This technique is important for investigation because it presents noticeable effects, such as generation of system logs and anomalous network traffic. This technique also occurs early in the timeline, and detection of this technique will effectively halt all future events. If the Standard Application Layer Protocol technique is detected and prevented, then subsequent techniques are not executed. Terminating the chain of techniques at the Standard Application Layer Protocol technique would limit operational damage. Of the six observables associated with this technique, four of these observables are assessed to be highly perceivable (Connection to External C2 Network, Unique Victim Hash Created and Sent to C2 Servers Via HTTP, HTTP POST Request to C2 IPs, Missing Files).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                 |
|---------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 11 artifacts could be generated by the Standard Application Layer Protocol technique |
| <b>Technique Observers</b>                                    | IT Staff and IT Cybersecurity                                                                   |

### 3.5. CONNECTION PROXY TECHNIQUE (T0884) FOR COMMAND AND CONTROL

Adversaries have been known to use The Onion Router (TOR) to establish a multi-hop proxy network with layers of encryption to protect the routing information and data being exfiltrated.<sup>14</sup> TOR was used during the attack on Colonial, as the ransomware note left on the operator's computer directed the company to a TOR address with links to the exfiltrated data.<sup>15</sup>

Network administrators, IT staff, and IT cybersecurity personnel could likely observe unexpected application communication to the network proxy port, unusual processes accessing the network proxy port, observed via firewall logs, and a significant observable, unusual network or host communication identified in network proxy logs.

A total of five observables were identified with the use of the Connection Proxy technique (T0884). Four of these observables are assessed to be highly perceivable (Victim Connects to C2 Network via TOR, Unexpected Application Communication from the Victim to the Network Proxy Port, Unusual Processes Accessing Network Proxy Port, Firewall Logs).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                             |
|---------------------------------------------------------------|-----------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 6 artifacts could be generated by the Connection Proxy technique |
| <b>Technique Observers</b>                                    | IT Staff and IT Cybersecurity                                               |

### 3.6. DATA FROM INFORMATION REPOSITORIES TECHNIQUE (T0811) FOR COLLECTION

As the DarkSide ransomware proliferates through the victim's system, it collects data about the infected environment by loading the libraries instructed by the dynamic-link library (DLL).<sup>16</sup> The ransomware harvests standard information on the system, such as OS, username, hostname, domain, and OS architecture, then encrypts the data and sends it to the C2 server. The ransomware also performs a default language check: if the default language is Russian or another Eastern European language, it will initiate a stop protocol and self-delete, as the DarkSide actors allegedly will not attack Russian entities.<sup>17</sup>

System and network administrators in IT and OT environments may have had access to observables associated with systems infected with the DarkSide ransomware. This assessment is based on the responsibilities typically assigned to these job positions to investigate anomalous network and system activity.<sup>18</sup>

A total of three observables were identified with the use of the Data from Information Repositories technique (T0811). These observables might have been visible to the network administrator, IT staff, and IT cybersecurity, and if identified and investigated earlier in the attack could have reduced comprehension time. This technique is important for investigation because it presents perceivable effects, such as deletion of volume shadow copies. This technique also occurs in the middle of the timeline, and detection of this technique will effectively halt all future events. This technique collects the host operating system files and any files stored on local and external drives, resulting in the host being placed into a compromised state. If system backups are created after this technique is executed, data recovery and disaster recovery efforts will be impaired. None of the observables are highly perceivable.

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                |
|---------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 34 artifacts could be generated by the Data from Information Repositories technique |
| <b>Technique Observers</b>                                    | OT Staff, OT Cybersecurity, IT Staff, and IT Cybersecurity                                     |

### 3.7. THEFT OF OPERATIONAL INFORMATION TECHNIQUE (T0882) FOR IMPACT

Adversaries not only encrypt system files and restrict access to vital databases, but may also exfiltrate data to the C2 server and threaten to release the stolen information if the victim refuses to pay the ransom. DarkSide ransomware uses Salsa20 and RSA-1024 encryption to guarantee the victim will not be able to decrypt the data without the adversary's decryption tool, which is provided upon payment of the ransom.<sup>19</sup> Not only are local files at risk, but any connected directories and removeable disks can become targets of the DarkSide ransomware. Within each encrypted directory, a README.TXT file is created housing a copy of the ransom note.<sup>20,21</sup>

In the case of Colonial, adversaries were able to encrypt the victim's system files and exfil more than 100 GB of company data. The adversary threatens to publicly release the data if the company refuses to pay the ransom.

System and network administrators in IT and OT environments along with onsite operators may have had access to observables associated with systems infected with the DarkSide ransomware. This assessment is based on the responsibilities typically assigned to these job positions to investigate anomalous network and system activity.

Observables associated with theft of operational information for DarkSide ransomware are captured in Yara rules, as follows:<sup>22</sup>

```
1A700F845849E573AB3148DAEf1A3B0B
7CDAC4B82A7573AE825E5EDB48F80BE5
```

A total of five observables were identified with the use of the Theft of Operational Information technique (T0882). These observables likely would have been visible to the network administrator, OT staff, OT cybersecurity, IT staff, and IT cybersecurity, and if identified and investigated earlier in the attack would have reduced comprehension time. This technique is important for investigation because it presents noticeable effects, such as large amounts of data being packaged, a surge in data upload size, and generation of malicious network traffic regarding the exfiltration of host data. This technique occurs in the middle of the intrusion timeline. All five of these observables are assessed to be highly perceivable.

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                             |
|---------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 3 artifacts could be generated by the Theft of Operational Information technique |
| <b>Technique Observers</b>                                    | OT Staff, OT Cybersecurity, IT Staff, and IT Cybersecurity                                  |



### 3.8. DATA DESTRUCTION TECHNIQUE (T0809) FOR INHIBIT RESPONSE FUNCTION

Adversaries employed the use of the Data Destruction technique (T0809) by using a DarkSide ransomware variant in the cyber-attack which emptied Recycle Bins of infected systems and removed shadow copies of files to ensure data recovery was unavailable to the victim. If the victim system was running windows system WOW64, the ransomware would execute a PowerShell command intended to delete shadow copies of the file system to prevent recovery.<sup>23,24</sup>

System and network administrators in IT environments may have had access to observables associated with systems infected with the DarkSide ransomware. This assessment is based on the responsibilities typically assigned to these job positions to investigate anomalous network and system activity.

A total of 11 observables were identified with the use of the Data Destruction technique (T0809). These observables likely would have been visible to the network administrator, IT staff, and IT cybersecurity, and if identified and investigated earlier in the attack would have reduced comprehension time. This technique is important for investigation because of its significant impact to the operational capabilities of a host through program execution and memory corruption. This technique is the most devastating and inhibits recovery attempts made by the victim through its file encryption and recovery attempt failure observables. Detection of this technique would enable a response to be made by the victim before significant file encryption spreads throughout the host network. System backups taken after this technique is executed will impact data recovery and disaster recovery efforts. Of the 11 observables associated with this technique, six of these observables are assessed to be highly perceivable (Removes Volume Shadow Copies, File Encryption, Missing Files, Memory Corruption, System Application Interruption, Event Log Creation).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                              |
|---------------------------------------------------------------|------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 26 artifacts could be generated by the Data Destruction technique |
| <b>Technique Observers</b>                                    | IT Staff and IT Cybersecurity                                                |

### 3.9. SERVICE STOP TECHNIQUE (T0881) FOR INHIBIT RESPONSE FUNCTION

The DarkSide ransomware kills targeted running Windows services and operating processes to eliminate file handles used by services throughout the system.<sup>25</sup> Applications stopped across infected systems would have been an observable both IT and OT personnel would have been able to see. However, with it being at the end of the cyber kill chain, any defensive measures taken would have to be deployed immediately.

There is no publicly available information concerning the specific services stopped. DarkSide ransomware variants have targeted the following services: vss, sql, svc\$, memtas, mepocs, sophos, veeam, and backup. Not only are these services stopped but they are deleted to prevent any possibility of data recovery outside of the decryption tool sold by the adversary.

A total of 11 observables were identified with the use of the Service Stop technique (T0881). All of these observables would likely be perceived.

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                |
|---------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 12 artifacts could be generated by the Service Stop technique                       |
| <b>Technique Observers</b>                                    | Engineering, OT Staff, OT Cybersecurity, IT Staff, IT Cybersecurity, Management, Support Staff |

3.10. LOSS OF AVAILABILITY TECHNIQUE (T0826) FOR IMPACT

The Colonial cyber-attack produced a unique look into the Loss of Availability technique (T0826) and the impact it had on the OT sector strictly from the IT side. The OT segments of the network were left intact and operational; however, Colonial deemed it unsafe to continue automated operations and shut down the pipeline to prevent the spread of the ransomware infection from the IT to the OT network.<sup>26</sup>

Once the DarkSide ransomware had encrypted system files across the IT network, operators were unable to access required information to continue business operations. As operators attempted to start normal functions, they found applications failing to run, user data missing, and system files that were inaccessible due to modification. The information servers connected to the SCADA systems on the OT network, where critical process information is stored, were unavailable due to encryption by the ransomware.<sup>27</sup> These systems were taken offline until a secure operational process could be guaranteed, effectively halting automated processes until limited manual operations could be initiated.

A total of eight observables were identified with the use of the Loss of Availability technique (T0826). Seven of these observables are assessed to be highly perceivable (Inability to Utilize Services within the IT Network, Inability to Access Systems within the OT Network, Encrypted System Files, Failed Attempt to Start Normal Functions, Application Failing to Run, Missing User Data, Inaccessible System Files Due to Modification).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                |
|---------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| Artifacts (See Appendix B)                                    | A total of 8 artifacts could be generated by the Loss of Availability technique                |
| Technique Observers                                           | Engineering, OT Staff, OT Cybersecurity, IT Staff, IT Cybersecurity, Management, Support Staff |

### 3.11. LOSS OF PRODUCTIVITY AND REVENUE (T0828) FOR IMPACT

Under normal operations Colonial, the largest refined product pipeline in the United States, supplies nearly 2.5 million barrels per day of fuel to 260 locations along its run from Texas to the East Coast. In 2020 the company generated a net income of \$420 million on \$1.3 billion in revenues. A week's loss from the DarkSide ransomware attack equates to roughly \$8 million in net income and \$25 million in revenues.<sup>28</sup> In addition, the adversaries demanded a ransom of \$4.4 million in cryptocurrency on 7 May, which Colonial paid the following day. This loss, however, was partially mitigated when federal authorities recovered \$2.3 million in early June.<sup>29</sup>

A total of four observables were identified with the use of the Loss of Productivity and Revenue technique (T0828). All of the observables are assessed to be highly perceivable (Loss of Productivity, Loss of Net Income, Loss of Revenue, Loss of Ransom Payment).

Please see Appendix A for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                |
|---------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| <b>Artifacts</b> (See Appendix B)                             | A total of 5 artifacts could be generated by the Loss of Productivity and Revenue technique    |
| <b>Technique Observers</b>                                    | Engineering, OT Staff, OT Cybersecurity, IT Staff, IT Cybersecurity, Management, Support Staff |

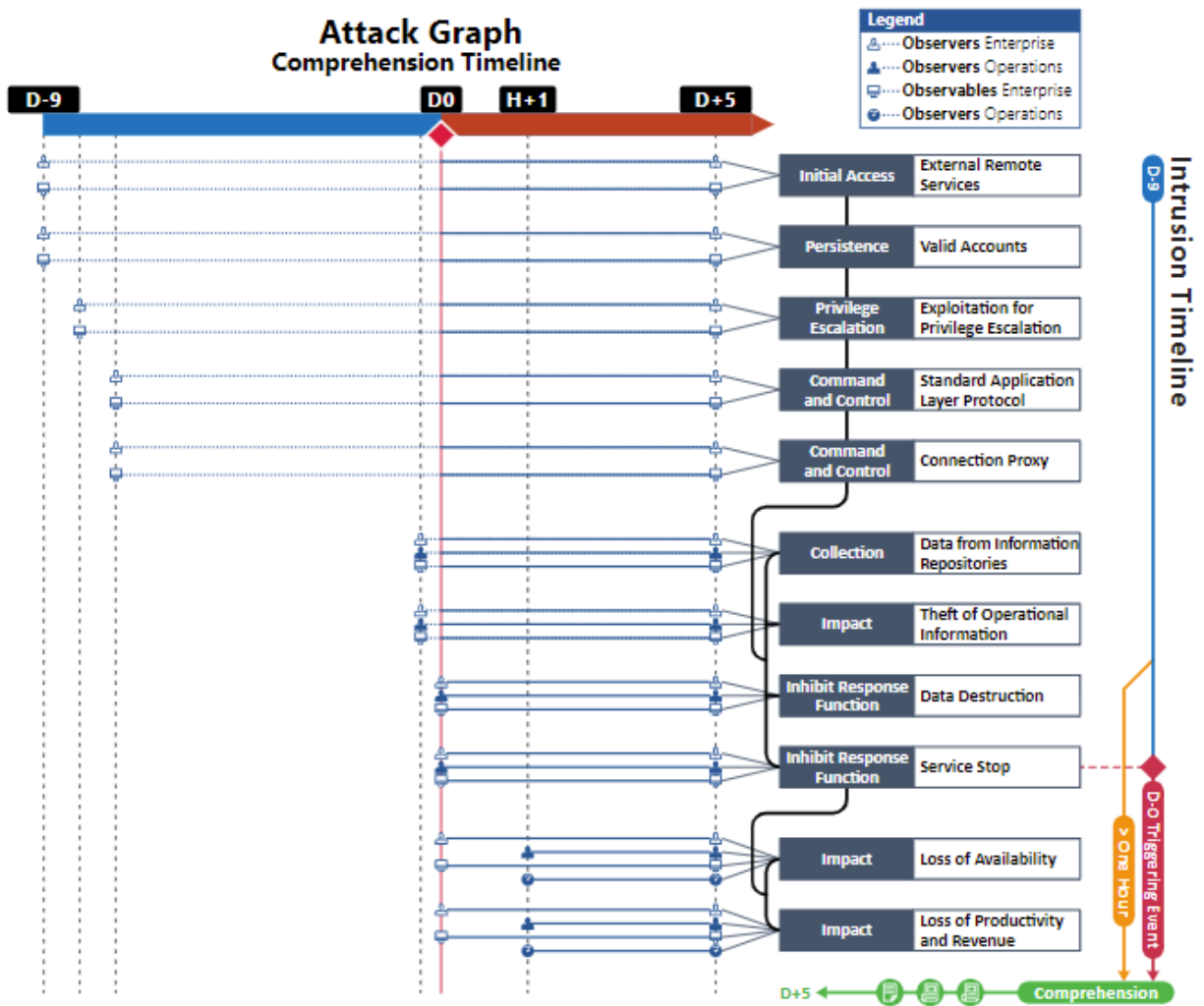


Figure 3. Attack Graph

## APPENDIX A: OBSERVABLES LIBRARY

The observables listed here were associated or believed to be associated with the ransomware attack on Colonial.

| Observables Associated with External Remote Services (T0822) |                                               |
|--------------------------------------------------------------|-----------------------------------------------|
| <b>Observable 1</b>                                          | VPN Account Usage                             |
| <b>Observable 2</b>                                          | VPN Connection to Internal Enterprise Network |
| <b>Observable 3</b>                                          | VPN Authentication Log                        |
| <b>Observable 4</b>                                          | VPN Activity Timestamp                        |

| Observables Associated with Valid Accounts Technique (T0859) |                                                    |
|--------------------------------------------------------------|----------------------------------------------------|
| <b>Observable 1</b>                                          | Leaked Credentials and Passwords Found On Internet |
| <b>Observable 2</b>                                          | VPN Legacy Account Usage                           |
| <b>Observable 3</b>                                          | VPN Authentication Log                             |
| <b>Observable 4</b>                                          | VPN Activity Timestamp                             |

| Observables Associated with Exploitation for Privilege Escalation Technique (T0890) |                                                                  |
|-------------------------------------------------------------------------------------|------------------------------------------------------------------|
| <b>Observable 1</b>                                                                 | Security Event Log                                               |
| <b>Observable 2</b>                                                                 | Malware Checking for Administration Privileges                   |
| <b>Observable 3</b>                                                                 | User Account Control (UAC) Running with Administrator Privileges |
| <b>Observable 4</b>                                                                 | Programs Running with Elevated Privileges                        |
| <b>Observable 5</b>                                                                 | Application Execution Log                                        |
| <b>Observable 6</b>                                                                 | System Log with Elevated Privileges                              |
| <b>Observable 7</b>                                                                 | Windows Defender Event Log                                       |

| Observables Associated with Standard Application Layer Protocol Technique (T0869) |                                                                                 |
|-----------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| <b>Observable 1</b>                                                               | Ransomware Gathers Victim System Information and Other Identifiable Information |
| <b>Observable 2</b>                                                               | Connection to External C2 Network                                               |
| <b>Observable 3</b>                                                               | Unique Victim Hash Created and Sent to C2 Servers via HTTP                      |
| <b>Observable 4</b>                                                               | Communications with External Ips                                                |
| <b>Observable 5</b>                                                               | HTTP POST Request to C2 IPs                                                     |
| <b>Observable 6</b>                                                               | Missing Files                                                                   |

| Observables Associated with Connection Proxy Technique (T0884) |                                                                                |
|----------------------------------------------------------------|--------------------------------------------------------------------------------|
| <b>Observable 1</b>                                            | Victim Connects to C2 Network via TOR                                          |
| <b>Observable 2</b>                                            | Encrypted Data Being Exfiltrated                                               |
| <b>Observable 3</b>                                            | Unexpected Application Communication from The Victim to The Network Proxy Port |
| <b>Observable 4</b>                                            | Unusual Processes Accessing Network Proxy Port                                 |
| <b>Observable 5</b>                                            | Firewall Logs                                                                  |

| Observables Associated with Data from Information Repositories Technique (T0811) |                                                                                 |
|----------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| <b>Observable 1</b>                                                              | Victim Data Collection via DLL Execution                                        |
| <b>Observable 2</b>                                                              | Ransomware Gathers Victim System Information and Other Identifiable Information |
| <b>Observable 3</b>                                                              | Ransomware Checks Victim Language, and Halts if Language Is Russian             |

| Observables Associated with Theft of Operation Information Technique (T0882) |                                                       |
|------------------------------------------------------------------------------|-------------------------------------------------------|
| <b>Observable 1</b>                                                          | Encryption of Victim Files Using Salsa20 And RSA-1024 |
| <b>Observable 2</b>                                                          | Exfil Victim Data to C2 Network                       |
| <b>Observable 3</b>                                                          | Creation of README.TXT File Containing Ransom Note    |
| <b>Observable 4</b>                                                          | Yara Rule String: 1A700F845849E573AB3148DAEf1A3B0B    |
| <b>Observable 5</b>                                                          | Yara Rule String: 7CDAC4B82A7573AE825E5EDB48F80BE5    |

| Observables Associated with Data Destruction Technique (T0809) |                                                             |
|----------------------------------------------------------------|-------------------------------------------------------------|
| <b>Observable 1</b>                                            | Recycle Bin Emptied                                         |
| <b>Observable 2</b>                                            | Removes Volume Shadow Copies                                |
| <b>Observable 3</b>                                            | Check if Victim Is Running a 64-Bit Windows OS              |
| <b>Observable 4</b>                                            | Delete Shadow Copies of File System if OS Is 64-Bit Windows |
| <b>Observable 5</b>                                            | Recovery Attempt Failures                                   |
| <b>Observable 6</b>                                            | File Encryption                                             |
| <b>Observable 7</b>                                            | Missing Files                                               |
| <b>Observable 8</b>                                            | Memory Corruption                                           |
| <b>Observable 9</b>                                            | System Calls                                                |
| <b>Observable 10</b>                                           | System Application Interruption                             |
| <b>Observable 11</b>                                           | Event Log Creation                                          |

| Observables Associated with Service Stop Technique (T0881) |                          |
|------------------------------------------------------------|--------------------------|
| <b>Observable 1</b>                                        | Services Stopped         |
| <b>Observable 2</b>                                        | vss stop                 |
| <b>Observable 3</b>                                        | sql stop                 |
| <b>Observable 4</b>                                        | svc\$ stop               |
| <b>Observable 5</b>                                        | memtas stop              |
| <b>Observable 6</b>                                        | mepocs stop              |
| <b>Observable 7</b>                                        | sophos stop              |
| <b>Observable 8</b>                                        | veeam stop               |
| <b>Observable 9</b>                                        | backup stop              |
| <b>Observable 10</b>                                       | Running Processes Killed |
| <b>Observable 11</b>                                       | Deletion of Services     |

| Observables Associated with Loss of Availability Technique (T0826) |                                                     |
|--------------------------------------------------------------------|-----------------------------------------------------|
| <b>Observable 1</b>                                                | Inability to Utilize Services Within the IT Network |
| <b>Observable 2</b>                                                | Inability to Access Systems Within the OT Network   |
| <b>Observable 3</b>                                                | Encrypted System Files                              |
| <b>Observable 4</b>                                                | Unable to Access Required Information               |
| <b>Observable 5</b>                                                | Failed Attempt to Start Normal Functions            |
| <b>Observable 6</b>                                                | Application Failing to Run                          |
| <b>Observable 7</b>                                                | Missing User Data                                   |
| <b>Observable 8</b>                                                | Inaccessible System Files Due to Modification       |

| Observables Associated with Loss of Productivity and Revenue Technique (T0828) |                                              |
|--------------------------------------------------------------------------------|----------------------------------------------|
| <b>Observable 1</b>                                                            | Loss of Five Days of Productivity            |
| <b>Observable 2</b>                                                            | Approximately \$8 Million Lost in Net Income |
| <b>Observable 3</b>                                                            | Approximately \$25 Million Lost in Revenue   |
| <b>Observable 4</b>                                                            | Loss of \$4.4 Million for Ransom Payment     |



## APPENDIX B: ARTIFACTS LIBRARY

| Artifacts Associated with External Remote Services (T0822) |                                                   |
|------------------------------------------------------------|---------------------------------------------------|
| <b>Artifact 1</b>                                          | Remote Services Protocols                         |
| <b>Artifact 2</b>                                          | Remote Vendor Connections                         |
| <b>Artifact 3</b>                                          | Session Authentication                            |
| <b>Artifact 4</b>                                          | Failed Logons Event ID 4625                       |
| <b>Artifact 5</b>                                          | Session Timestamp                                 |
| <b>Artifact 6</b>                                          | Logon Event Type 3                                |
| <b>Artifact 7</b>                                          | Logon Event Type 10                               |
| <b>Artifact 8</b>                                          | Logon Event Type 11                               |
| <b>Artifact 9</b>                                          | Remote Session Key                                |
| <b>Artifact 10</b>                                         | System Registry Network Interfaces                |
| <b>Artifact 11</b>                                         | Remote Services Logon                             |
| <b>Artifact 12</b>                                         | Remote Services Logon                             |
| <b>Artifact 13</b>                                         | Session Logoff Event ID 4634/4647                 |
| <b>Artifact 14</b>                                         | Domain Controller Log                             |
| <b>Artifact 15</b>                                         | User Account Name                                 |
| <b>Artifact 16</b>                                         | User Client Address                               |
| <b>Artifact 17</b>                                         | Security Account Manager Registry Entries         |
| <b>Artifact 18</b>                                         | Dialog Box Pop-Up                                 |
| <b>Artifact 19</b>                                         | Mouse Movement                                    |
| <b>Artifact 20</b>                                         | Command Prompt Window Opened                      |
| <b>Artifact 21</b>                                         | Security Account Manager Registry Password Hashes |
| <b>Artifact 22</b>                                         | External IP Address                               |
| <b>Artifact 23</b>                                         | External IP Address                               |
| <b>Artifact 24</b>                                         | User Privileges Change                            |
| <b>Artifact 25</b>                                         | Blocked Incoming Connections Event ID 5031        |
| <b>Artifact 26</b>                                         | Blocked Incoming Packet Event ID 5152             |
| <b>Artifact 27</b>                                         | Encrypted Network Traffic                         |
| <b>Artifact 28</b>                                         | Mouse Movement                                    |
| <b>Artifact 29</b>                                         | Cursor Movement                                   |

| Artifacts Associated with External Remote Services (T0822) |                                         |
|------------------------------------------------------------|-----------------------------------------|
| <b>Artifact 30</b>                                         | Keyboard Entries                        |
| <b>Artifact 31</b>                                         | Application Execution Via Input Devices |
| <b>Artifact 32</b>                                         | Prefetch Files Created                  |
| <b>Artifact 33</b>                                         | External MAC Address                    |
| <b>Artifact 34</b>                                         | External MAC Address                    |
| <b>Artifact 35</b>                                         | RDP Connections                         |
| <b>Artifact 36</b>                                         | Program Executions                      |
| <b>Artifact 37</b>                                         | Code Injections                         |
| <b>Artifact 38</b>                                         | Host-Screen Adjustments                 |
| <b>Artifact 39</b>                                         | Screen Resolution Changes               |
| <b>Artifact 40</b>                                         | SSH Connections                         |
| <b>Artifact 41</b>                                         | Process Creations                       |
| <b>Artifact 42</b>                                         | Service Creation                        |
| <b>Artifact 43</b>                                         | Service Modification                    |
| <b>Artifact 44</b>                                         | Event Log Creation                      |
| <b>Artifact 45</b>                                         | Event Log Creation                      |
| <b>Artifact 46</b>                                         | Jumplist Creation                       |
| <b>Artifact 47</b>                                         | Shellbag Creation                       |
| <b>Artifact 48</b>                                         | System Resource Use Management Changes  |
| <b>Artifact 49</b>                                         | Network Connection Durations            |
| <b>Artifact 50</b>                                         | Changes in Bytes Sent and Received      |
| <b>Artifact 51</b>                                         | Increase CPU Cycles                     |
| <b>Artifact 52</b>                                         | Host System Crash                       |
| <b>Artifact 53</b>                                         | Application Usage Increase              |
| <b>Artifact 54</b>                                         | Network Bandwidth Changes               |
| <b>Artifact 55</b>                                         | Logon Event ID 4624                     |
| <b>Artifact 56</b>                                         | Logon Event ID 4624                     |
| <b>Artifact 57</b>                                         | SMB Port 445                            |
| <b>Artifact 58</b>                                         | RDP Port 3389                           |
| <b>Artifact 59</b>                                         | SSH Port 22                             |

| Artifacts Associated with Valid Accounts (T0859) |                                        |
|--------------------------------------------------|----------------------------------------|
| <b>Artifact 1</b>                                | Logons                                 |
| <b>Artifact 2</b>                                | Application Log                        |
| <b>Artifact 3</b>                                | Domain Permission Requests             |
| <b>Artifact 4</b>                                | Permission Elevation Requests          |
| <b>Artifact 5</b>                                | Application Use Times                  |
| <b>Artifact 6</b>                                | Configuration Changes                  |
| <b>Artifact 7</b>                                | Prefetch Files Created After Execution |
| <b>Artifact 8</b>                                | Logon Session Creation                 |
| <b>Artifact 9</b>                                | User Account Creation                  |
| <b>Artifact 10</b>                               | Authentication Creation                |
| <b>Artifact 11</b>                               | System Logs                            |
| <b>Artifact 12</b>                               | Successful Logon Event ID 4624         |
| <b>Artifact 13</b>                               | Failed Logons Event ID 4625            |
| <b>Artifact 14</b>                               | Logon Timestamp                        |
| <b>Artifact 15</b>                               | Logon Type Entry                       |

| Artifacts Associated with Exploitation for Privilege Escalation (T0890) |                                                                                     |
|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <b>Artifact 1</b>                                                       | Unexpected Process Crash                                                            |
| <b>Artifact 2</b>                                                       | Unusual Process Activity                                                            |
| <b>Artifact 3</b>                                                       | Sysmon Event 8 CreateRemoteThread Process Injection Detected                        |
| <b>Artifact 4</b>                                                       | Unusual Command Line History Associated with Known CVE Techniques                   |
| <b>Artifact 5</b>                                                       | Suspicious File Write to System Directory Followed by Privileged Execution of File  |
| <b>Artifact 6</b>                                                       | Execution of a Suspicious File in System32 or Windows Directory at Privileged Level |
| <b>Artifact 7</b>                                                       | Unusual or Unexpected Kerberos Ticket Requests                                      |
| <b>Artifact 8</b>                                                       | Suspicious Files Written to Disk                                                    |
| <b>Artifact 9</b>                                                       | Suspicious Program Running Under SYSTEM or Other Elevated Account                   |
| <b>Artifact 10</b>                                                      | Driver Loaded                                                                       |
| <b>Artifact 11</b>                                                      | Network Traffic Matching Vulnerability                                              |
| <b>Artifact 12</b>                                                      | Abnormal Reads/Writes Between Processes                                             |
| <b>Artifact 13</b>                                                      | Unusual Command Line Arguments to Application                                       |

| Artifacts Associated with Exploitation for Privilege Escalation (T0890) |                                                                    |
|-------------------------------------------------------------------------|--------------------------------------------------------------------|
| <b>Artifact 14</b>                                                      | Artifacts Associated with Known Privilege Escalation CVEs          |
| <b>Artifact 15</b>                                                      | Unusual or Unexpected Child Process Running at Elevated Privileges |

| Artifacts Associated with Standard Application Layer Protocol (T0869) |                                            |
|-----------------------------------------------------------------------|--------------------------------------------|
| <b>Artifact 1</b>                                                     | External Network Connections               |
| <b>Artifact 2</b>                                                     | Increase In Number of External Connections |
| <b>Artifact 3</b>                                                     | Network Content Metadata                   |
| <b>Artifact 4</b>                                                     | Network Connection Times                   |
| <b>Artifact 5</b>                                                     | HTTP Traffic Port 80                       |
| <b>Artifact 6</b>                                                     | DNS Traffic Port 53                        |
| <b>Artifact 7</b>                                                     | SMB Traffic Port 445                       |
| <b>Artifact 8</b>                                                     | HTTPS Traffic Port 443                     |
| <b>Artifact 9</b>                                                     | RDP Traffic Port 3389                      |
| <b>Artifact 10</b>                                                    | HTTP Post Request                          |
| <b>Artifact 11</b>                                                    | External IP Addresses                      |

| Artifacts Associated with Connection Proxy (T0884) |                                                                                   |
|----------------------------------------------------|-----------------------------------------------------------------------------------|
| <b>Artifact 1</b>                                  | Unexpected Application Communication to Network Proxy Port in Command Line Output |
| <b>Artifact 2</b>                                  | Unexpected Process Usage of Network Proxy Port Observed Via Memory                |
| <b>Artifact 3</b>                                  | Unexpected Process Usage of Network Proxy Port Observed Via OS Logs               |
| <b>Artifact 4</b>                                  | Unexpected Process Usage of Network Proxy Port Observed Via Firewall Logs         |
| <b>Artifact 5</b>                                  | Unexpected Host Communicating with Network Proxy Port on Industrial Asset         |
| <b>Artifact 6</b>                                  | Unusual Network or Host Communications Identified in Network Proxy Log            |

| Artifacts Associated with Data from Information Repositories (T0884) |                         |
|----------------------------------------------------------------------|-------------------------|
| <b>Artifact 1</b>                                                    | Database Request        |
| <b>Artifact 2</b>                                                    | Authentication Attempts |
| <b>Artifact 3</b>                                                    | Authentication Success  |
| <b>Artifact 4</b>                                                    | Authentication Failure  |

| Artifacts Associated with Data from Information Repositories (T0884) |                                         |
|----------------------------------------------------------------------|-----------------------------------------|
| <b>Artifact 5</b>                                                    | RDP Traffic Port 3389                   |
| <b>Artifact 6</b>                                                    | SSH Traffic Port 22                     |
| <b>Artifact 7</b>                                                    | VNC Traffic Port 5900                   |
| <b>Artifact 8</b>                                                    | FTP Traffic Port 21                     |
| <b>Artifact 9</b>                                                    | SFTP Traffic Port 22                    |
| <b>Artifact 10</b>                                                   | Telnet Traffic Port 23                  |
| <b>Artifact 11</b>                                                   | MSSQL Traffic                           |
| <b>Artifact 12</b>                                                   | MSSQL Traffic                           |
| <b>Artifact 13</b>                                                   | HTTPS Traffic Port 443                  |
| <b>Artifact 14</b>                                                   | HTTP Traffic Port 80                    |
| <b>Artifact 15</b>                                                   | Engineering Workstation Application Log |
| <b>Artifact 16</b>                                                   | Operational Database Logons             |
| <b>Artifact 17</b>                                                   | Operational Database Data Modification  |
| <b>Artifact 18</b>                                                   | File Access                             |
| <b>Artifact 19</b>                                                   | File Modification                       |
| <b>Artifact 20</b>                                                   | MRU List Change                         |
| <b>Artifact 21</b>                                                   | Recent Search List                      |
| <b>Artifact 22</b>                                                   | Remote Procedure Calls                  |
| <b>Artifact 23</b>                                                   | Remote Procedure Calls                  |
| <b>Artifact 24</b>                                                   | Jump Host Credentials Accessed          |
| <b>Artifact 25</b>                                                   | Personnel List Files Accessed           |
| <b>Artifact 26</b>                                                   | Traffic Timestamps                      |
| <b>Artifact 27</b>                                                   | Design Documentation Manipulation       |
| <b>Artifact 28</b>                                                   | Design Documentation Access             |
| <b>Artifact 29</b>                                                   | TDS Port 1433                           |
| <b>Artifact 30</b>                                                   | Application Logon                       |
| <b>Artifact 31</b>                                                   | User Session Creation                   |
| <b>Artifact 32</b>                                                   | Data Bytes Sent                         |
| <b>Artifact 33</b>                                                   | Project File Modification               |
| <b>Artifact 34</b>                                                   | SMB Traffic                             |

| Artifacts Associated with Theft of Operational Information (T0822) |                                                                                                                     |
|--------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| <b>Artifact 1</b>                                                  | Exfiltration of Endpoint Host Data (Spreadsheets, Diagrams, Documents, Configurations, Etc.) Via Standard Protocols |
| <b>Artifact 2</b>                                                  | Exfiltration From Database Via Standard Queries                                                                     |
| <b>Artifact 3</b>                                                  | Exfiltration of Operational Info Via Phishing                                                                       |

| Artifacts Associated with Data Destruction (T0809) |                                 |
|----------------------------------------------------|---------------------------------|
| <b>Artifact 1</b>                                  | Program Execution               |
| <b>Artifact 2</b>                                  | SFTP Port 22                    |
| <b>Artifact 3</b>                                  | FTPS Port 990                   |
| <b>Artifact 4</b>                                  | SMB Port 139, 445               |
| <b>Artifact 5</b>                                  | HTTP Port 80                    |
| <b>Artifact 6</b>                                  | HTTPS Port 443                  |
| <b>Artifact 7</b>                                  | Command Line Arguments          |
| <b>Artifact 8</b>                                  | SCP Port 22                     |
| <b>Artifact 9</b>                                  | Memory Corruption               |
| <b>Artifact 10</b>                                 | Files Moved to Recycle Bin      |
| <b>Artifact 11</b>                                 | Non-Native Files                |
| <b>Artifact 12</b>                                 | Non-Native Files                |
| <b>Artifact 13</b>                                 | External Network Connections    |
| <b>Artifact 14</b>                                 | Local Network Connections       |
| <b>Artifact 15</b>                                 | Host System Reboot Failure      |
| <b>Artifact 16</b>                                 | Process Logic Failure           |
| <b>Artifact 17</b>                                 | Event Log Creation              |
| <b>Artifact 18</b>                                 | System Call                     |
| <b>Artifact 19</b>                                 | System Application Interruption |
| <b>Artifact 20</b>                                 | Device Failure                  |
| <b>Artifact 21</b>                                 | Recovery Attempt Failure        |
| <b>Artifact 22</b>                                 | File Encryptions                |
| <b>Artifact 23</b>                                 | Missing Files                   |
| <b>Artifact 24</b>                                 | Use of File Transfer Protocols  |
| <b>Artifact 25</b>                                 | FTP Port 20, 21                 |

**Artifacts Associated with Data Destruction (T0809)**

|                    |              |
|--------------------|--------------|
| <b>Artifact 26</b> | TFTP Port 60 |
|--------------------|--------------|

**Artifacts Associated with Service Stop (T0881)**

|                    |                                                        |
|--------------------|--------------------------------------------------------|
| <b>Artifact 1</b>  | Process Failure                                        |
| <b>Artifact 2</b>  | Sysinternals Logs                                      |
| <b>Artifact 3</b>  | Application Error Messages                             |
| <b>Artifact 4</b>  | Process Error Messages                                 |
| <b>Artifact 5</b>  | Application Service Stop                               |
| <b>Artifact 6</b>  | OS Service Stop                                        |
| <b>Artifact 7</b>  | System Event Logs                                      |
| <b>Artifact 8</b>  | Application Event Logs                                 |
| <b>Artifact 9</b>  | OS API Call                                            |
| <b>Artifact 10</b> | Command Line System Argument                           |
| <b>Artifact 11</b> | System Resource Usage Manager Application Usage Change |
| <b>Artifact 12</b> | Registry Change HKLM\System\CurrentControlSet\Services |

**Artifacts Associated with Loss of Availability (T0826)**

|                   |                                                                                                               |
|-------------------|---------------------------------------------------------------------------------------------------------------|
| <b>Artifact 1</b> | Operator or User Discovery of Encrypted or Inoperable Systems                                                 |
| <b>Artifact 2</b> | Significant Logged Usage of Native Crypto Functions or Presence of Import of Crypto Functions in Binaries     |
| <b>Artifact 3</b> | Significant Reduction or Increase in Network Traffic Due to Malware Propagation of Disappearance of Services  |
| <b>Artifact 4</b> | Unexplained Loss of Application Data                                                                          |
| <b>Artifact 5</b> | Unexplained Loss of User Data                                                                                 |
| <b>Artifact 6</b> | Process Failure Due to Loss of Required Network or System Dependency                                          |
| <b>Artifact 7</b> | Changes In Network Routing or Usage of Redundant Control System Network Connection Due to Failed Network Path |
| <b>Artifact 8</b> | File System Modification Artifacts Might Be Present on Disk                                                   |

**Artifacts Associated with Loss of Productivity and Revenue (T0828)**

|                   |                                                                                                                         |
|-------------------|-------------------------------------------------------------------------------------------------------------------------|
| <b>Artifact 1</b> | Loss of Confidence in a Safety System Due to Unreliability Might Result in a Risk Management Driven Shutdown of a Plant |
|-------------------|-------------------------------------------------------------------------------------------------------------------------|

| Artifacts Associated with Loss of Productivity and Revenue (T0828) |                                                                                                                                                |
|--------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Artifact 2</b>                                                  | Worms or Other Types of Rapidly Propagating Malware Might Result in the Shutdown of a Plant to Prevent Ransomware or Other Destructive Attacks |
| <b>Artifact 3</b>                                                  | Extortion Attempts Might Lead to Reduced Operations Due to Potential Presence of Malicious Attackers                                           |
| <b>Artifact 4</b>                                                  | Loss of Control of Critical Systems Due to Ransomware or Loss of Confidence Might Lead to a Degraded Productivity or Revenue Operating State   |
| <b>Artifact 5</b>                                                  | File System Modification Artifacts Might be Present on Disk                                                                                    |



## APPENDIX C: OBSERVERS

This is a collection of standardized potential observers that work in operational technology organizations. It has been slightly modified by the CyOTE team from the Job Role Groupings listed in the SANS ICS Job Role to Competency Level Poster to communicate the categories of potential observers during cyber events.

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Engineering</b>  <ul style="list-style-type: none"><li>• Process Engineer</li><li>• Electrical, Controls, and Mechanical Engineer</li><li>• Project Engineer</li><li>• Systems and Reliability Engineer</li><li>• OT Developer</li><li>• PLC Programmer</li><li>• Emergency Operations Manager</li><li>• Plant Networking</li><li>• Control/Instrumentation Specialist</li><li>• Protection and Controls</li><li>• Field Engineer</li><li>• System Integrator</li></ul> | <b>Support Staff</b>  <ul style="list-style-type: none"><li>• Remote Maintenance &amp; Technical Support</li><li>• Contractors (engineering)</li><li>• IT and Physical Security Contractor</li><li>• Procurement Specialist</li><li>• Legal</li><li>• Contracting Engineer</li><li>• Insurance</li><li>• Supply-chain Participant</li><li>• Inventory Management/Lifecycle Management</li><li>• Physical Security Specialist</li></ul> |
| <b>Operations Technology (OT) Staff</b>  <ul style="list-style-type: none"><li>• Operator</li><li>• Site Security POC</li><li>• Technical Specialists (electrical/mechanical/chemical)</li><li>• ICS/SCADA Programmer</li></ul>                                                                                                                                                                                                                                            | <b>Information Technology (IT) Cybersecurity</b>  <ul style="list-style-type: none"><li>• ICS Security Analyst</li><li>• Security Engineering and Architect</li><li>• Security Operations</li><li>• Security Response and Forensics</li><li>• Security Management (CSO)</li><li>• Audit Specialist</li></ul>                                                                                                                          |
| <b>Operational Technology (OT) Cybersecurity</b>  <ul style="list-style-type: none"><li>• OT Security</li><li>• ICS/SCADA Security</li></ul>                                                                                                                                                                                                                                                                                                                             | <ul style="list-style-type: none"><li>• Security Tester</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Management</b>  <ul style="list-style-type: none"><li>• Plant Manager</li><li>• Risk/Safety Manager</li><li>• Business Unit Management</li><li>• C-level Management</li></ul>                                                                                                                                                                                                                                                                                         | <b>Information Technology (IT) Staff</b>  <ul style="list-style-type: none"><li>• Networking and Infrastructure</li><li>• Host Administrator</li><li>• Database Administrator</li><li>• Application Development</li><li>• ERP/MES Administrator</li><li>• IT Management</li></ul>                                                                                                                                                   |

## REFERENCES

- <sup>1</sup> [U.S. Senate Committee on Homeland Security and Governmental Affairs | Joseph Blount | “Testimony of Joseph Blount, President and Chief Executive Officer Colonial Pipeline Company” | <https://www.hsgac.senate.gov/imo/media/doc/Testimony-Blount-2021-06-08.pdf> | 8 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>2</sup> [Bloomberg | William Turton and Kartikay Mehrotra | “Hackers Breached Colonial Pipeline Using Compromised Password” | <https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password> | 4 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>3</sup> [Bloomberg | William Turton and Kartikay Mehrotra | “Hackers Breached Colonial Pipeline Using Compromised Password” | <https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password> | 4 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>4</sup> [Bloomberg | William Turton and Kartikay Mehrotra | “Hackers Breached Colonial Pipeline Using Compromised Password” | <https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password> | 4 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>5</sup> [Colonial Pipeline | “A Message to Our Customers and Those Who Depend on Us.” | [https://www.colpipe.com/safe-operations/cybersecurity-response?gclid=Cj0KCQjwh\\_eFBhDZARIsALHjIKcFyX6srFFwyDhqvIGH4ViV05lb7YG0b2ZazA1NCijn6ivM7ezYaqcaAswHEALw\\_wcB](https://www.colpipe.com/safe-operations/cybersecurity-response?gclid=Cj0KCQjwh_eFBhDZARIsALHjIKcFyX6srFFwyDhqvIGH4ViV05lb7YG0b2ZazA1NCijn6ivM7ezYaqcaAswHEALw_wcB) | 13 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>6</sup> [U.S. Senate Committee on Homeland Security and Governmental Affairs | Joseph Blount | “Testimony of Joseph Blount, President and Chief Executive Officer Colonial Pipeline Company” | <https://www.hsgac.senate.gov/imo/media/doc/Testimony-Blount-2021-06-08.pdf> | 8 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>7</sup> [Bloomberg | William Turton and Kartikay Mehrotra | “Hackers Breached Colonial Pipeline Using Compromised Password” | <https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password> | 4 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>8</sup> [Trend Micro | “What We Know About the DarkSide Ransomware and the US Pipeline Attack” | [https://www.trendmicro.com/en\\_us/research/21/e/what-we-know-about-DarkSide-ransomware-and-the-us-pipeline-attac.html](https://www.trendmicro.com/en_us/research/21/e/what-we-know-about-DarkSide-ransomware-and-the-us-pipeline-attac.html) | 12 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>9</sup> [U.S. Senate Committee on Homeland Security and Governmental Affairs | Joseph Blount | “Testimony of Joseph Blount, President and Chief Executive Officer Colonial Pipeline Company” | <https://www.hsgac.senate.gov/imo/media/doc/Testimony-Blount-2021-06-08.pdf> | 8 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>10</sup> [Bloomberg | William Turton and Kartikay Mehrotra | “Hackers Breached Colonial Pipeline Using Compromised Password” | <https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password> | 4 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>11</sup> [Bloomberg | William Turton and Kartikay Mehrotra | “Hackers Breached Colonial Pipeline Using Compromised Password” | <https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password> | 4 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]

- 
- <sup>12</sup> [Virsec | “Virsec Analysis of the Colonial Pipeline Attack” | <https://www.virsec.com/blog/virsec-analysis-of-the-colonial-pipeline-attack> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>13</sup> [Virsec | “Virsec Analysis of the Colonial Pipeline Attack” | <https://www.virsec.com/blog/virsec-analysis-of-the-colonial-pipeline-attack> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>14</sup> [Cybersecurity and Infrastructure Security Agency | “DarkSide Ransomware: Best Practices for Preventing Business Disruption from Ransomware Attacks” | <https://www.cisa.gov/uscert/ncas/alerts/aa21-131a> | Revised 8 July 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>15</sup> [Cybersecurity and Infrastructure Security Agency | “MAR-10337802-1.v1: DarkSide Ransomware” | <https://www.cisa.gov/uscert/ncas/analysis-reports/ar21-189a> | 8 July 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>16</sup> [Cybersecurity and Infrastructure Security Agency | “MAR-10337802-1.v1: DarkSide Ransomware” | <https://www.cisa.gov/uscert/ncas/analysis-reports/ar21-189a> | 8 July 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>17</sup> [Virsec | “Virsec Analysis of the Colonial Pipeline Attack” | <https://www.virsec.com/blog/virsec-analysis-of-the-colonial-pipeline-attack> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>18</sup> [Mandiant | Jordan Nuce and others | “Shining a Light on DARKSIDE Ransomware Operations” | <https://www.mandiant.com/resources/shining-a-light-on-DarkSide-ransomware-operations> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>19</sup> [Cybersecurity and Infrastructure Security Agency | “MAR-10337802-1.v1: DarkSide Ransomware” | <https://www.cisa.gov/uscert/ncas/analysis-reports/ar21-189a> | 8 July 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>20</sup> [Cybersecurity and Infrastructure Security Agency | “DarkSide Ransomware: Best Practices for Preventing Business Disruption from Ransomware Attacks” | <https://www.cisa.gov/uscert/ncas/alerts/aa21-131a> | Revised 8 July 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>21</sup> [Mandiant | Jordan Nuce and others | “Shining a Light on DARKSIDE Ransomware Operations” | <https://www.mandiant.com/resources/shining-a-light-on-DarkSide-ransomware-operations> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>22</sup> [Mandiant | Jordan Nuce and others | “Shining a Light on DARKSIDE Ransomware Operations” | <https://www.mandiant.com/resources/shining-a-light-on-DarkSide-ransomware-operations> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>23</sup> [Virsec | “Virsec Analysis of the Colonial Pipeline Attack” | <https://www.virsec.com/blog/virsec-analysis-of-the-colonial-pipeline-attack> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>24</sup> [Cybersecurity and Infrastructure Security Agency | “DarkSide Ransomware: Best Practices for Preventing Business Disruption from Ransomware Attacks” | <https://www.cisa.gov/uscert/ncas/alerts/aa21-131a> | Revised 8 July 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]

---

<sup>25</sup> [Virsec | “Virsec Analysis of the Colonial Pipeline Attack” | <https://www.virsec.com/blog/virsec-analysis-of-the-colonial-pipeline-attack> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>26</sup> [U.S. Senate Committee on Homeland Security and Governmental Affairs | Joseph Blount | “Testimony of Joseph Blount, President and Chief Executive Officer Colonial Pipeline Company” | <https://www.hsgac.senate.gov/imo/media/doc/Testimony-Blount-2021-06-08.pdf> | 8 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>27</sup> [Virsec | “Virsec Analysis of the Colonial Pipeline Attack” | <https://www.virsec.com/blog/virsec-analysis-of-the-colonial-pipeline-attack> | 11 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>28</sup> [Forbes | Christopher Helman | “Cyber-Ransom Of \$5m ‘Nothing’ To Colonial Pipeline, Which Has Paid Hundreds Of Millions In Dividends To Billionaire Koch Family” | <https://www.forbes.com/sites/christopherhelman/2021/05/14/cyber-ransom-of-5m-nothing-to-colonial-pipeline-which-has-paid-hundreds-of-millions-in-dividends-to-billionaire-koch-family/?sh=54a3131c2e6e> | 14 May 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>29</sup> [NPR | Vanessa Romo | “How A New Team Of Feds Hacked The Hackers And Got Colonial Pipeline's Ransom Back” | <https://www.npr.org/2021/06/08/1004223000/how-a-new-team-of-feds-hacked-the-hackers-and-got-colonial-pipelines-bitcoin-bac> | 8 June 2021 | Accessed 1 March 2022 | The source is publicly available information and does not contain classification markings]